

Suricata 실시간 이상탐지 구축 리포트

IDS 배치 위치 재설계 및 예약 API 대상 실전 탐지 검증

문서번호	IDS-2026-0706-01	작성일	2026-07-06
배치 서버	queue-gate (172.16.60.146)	Suricata 버전	8.0.5-0ubuntu1 (PPA: oisf/suricata-stable)
최초 배치	별도 monitor 서버 (172.16.60.135) — 변경됨	버전	1.0

1. 개요

예약 API(/api/book-seat)에 대한 비정상적인 반복 요청(봇/매크로 성 트래픽)을 실시간으로 탐지하기 위해 Suricata를 도입했다. 최초 계획은 별도의 monitor 서버에 Suricata와 ELK를 함께 배치하는 것이었으나, 실제 구축 과정에서 배치 위치에 따라 탐지 가능 여부가 갈린다는 것을 확인하고 구조를 변경했다.

2. 최초 배치 및 실패 원인

별도 monitor 서버(172.16.60.135)에 Suricata를 설치하고 HOME_NET을 172.16.60.0/24로 설정한 뒤, k6로 예약 API에 반복 요청을 발생시켰다. 그러나 monitor 서버의 fast.log에는 어떠한 알람도 기록되지 않았다.

원인: monitor 서버는 실제 사용자 트래픽 경로(맥북 → queue-gate → web-lb → was) 상에 위치하지 않는 독립된 서버였다. Suricata는 자신이 물리적으로 연결된 네트워크 인터페이스를 통과하는 패킷만 검사할 수 있으므로, 트래픽이 지나가지 않는 위치에서는 애초에 관찰할 패킷 자체가 존재하지 않아 탐지가 불가능했다. 가상 스위치 환경에서 별도의 포트 미러링(SPAN) 설정 없이는 이 문제를 해결할 수 없었다.

3. 배치 위치 변경

실제 트래픽이 반드시 통과하는 queue-gate(172.16.60.146)에 Suricata를 직접 설치하는 구조로 변경했다. queue-gate는 모든 사용자 요청이 Nginx를 통해 처리되기 전에 거쳐가는 지점이므로, 별도의 미러링 설정 없이도 전체 트래픽을 관찰할 수 있다.

4. 설치 및 설정

4.1 설치

Ubuntu 기본 저장소에는 suricata 패키지가 없어 저장소를 추가했다.

```
sudo add-apt-repository universe
sudo add-apt-repository ppa:oisf/suricata-stable
sudo apt update
sudo apt install -y suricata
```

4.2 설정 오류 수정

기본 설정 파일 그대로는 서비스가 기동되지 않았다. 확인된 오류와 조치는 아래와 같다.

오류 메시지	원인	조치
invalid size argument - 100 KiB	request-body-limit / response-body-limit 값의 단위 표기(KiB)가 Suricata 파서 문법과 불일치	100 KiB → 100kb로 일괄 치환
Unable to find iface eth0: No such device	설정 파일의 기본 인터페이스명(eth0)이 실제 인터페이스명(ens160)과 불일치	eth0 → ens160로 일괄 치환
No rule files match the pattern	default-rule-path(/var/lib/suricata/rules) 디렉터리가 비어 있음	탐지 룰 파일 신규 작성

```
sudo sed -i 's/HOME_NET:.*HOME_NET: "[172.16.60.0\24]"/' /etc/suricata/suricata.yaml
sudo sed -i 's/eth0/ens160/g' /etc/suricata/suricata.yaml
sudo sed -i 's/ KiB/kb/g; s/ MiB/mb/g' /etc/suricata/suricata.yaml
```

5. 탐지 룰

예약 API에 대한 반복 요청을 탐지하는 룰을 최초 아래와 같이 작성했으나, 키워드 순서 오류로 로딩에 실패했다.

```
# 1차 작성 (실패)
alert http any any -> any any (msg:"Excessive booking API calls detected";
  content:"/api/book-seat"; http.uri;
  threshold: type threshold, track by_src, count 20, seconds 10;
  sid:1000001; rev:1;)
```

```
# 오류: rule 1000001 setup buffer http_uri but didn't add matches to it
```

http.uri는 이후에 오는 content 키워드가 URI 버퍼를 대상으로 매칭하도록 지정하는 sticky buffer이므로, content보다 앞에 위치해야 한다. 순서를 수정하여 재작성했다.

```
# 최종 룰 (정상 로드됨)
alert http any any -> any any (msg:"Excessive booking API calls detected";
  http.uri; content:"/api/book-seat";
  threshold: type threshold, track by_src, count 20, seconds 10;
  sid:1000001; rev:1;)
```

```
$ sudo suricata --af-packet -c /etc/suricata/suricata.yaml -v 2>&1 | grep -i "rules"
Info - 1 rule files processed. 2 rules successfully loaded, 0 rules failed
Info - 2 signatures processed. 0 are IP-only rules, 0 are inspecting packet payload, 2 inspect application layer
```

6. 서비스 등록

```
sudo systemctl enable --now suricata
sudo systemctl status suricata
• suricata.service - Suricata IDS/IPS/NSM/FW daemon
  Active: active (running)
```

7. 실전 탐지 검증

7.1 공격 시뮬레이션 스크립트

```
import http from 'k6/http';

export const options = { vus: 10, duration: '15s' };

export default function () {
  http.post('http://172.16.60.146/api/book-seat', JSON.stringify({
    gameId: 1, seatId: 'A5', buyerName: 'attacker'
  })), { headers: { 'Content-Type': 'application/json' } });
}
```

7.2 실행 결과

```
$ k6 run ~/attack-sim.js
checks.....: 100.00%
http_reqs.....: 208373 13891.174941/s
running (15.0s), 00/10 VUs, 208373 complete and 0 interrupted iterations
```

7.3 탐지 로그

```
$ sudo tail -30 /var/log/suricata/fast.log
07/06/2026-21:57:58.691107 [**] [1:1000001:1] Excessive booking API calls detected
[**] [Classification: (null)] [Priority: 3] {TCP} 172.16.60.1:54571 -> 172.16.60.146:80
07/06/2026-21:57:58.693172 [**] [1:1000001:1] Excessive booking API calls detected
[**] [Classification: (null)] [Priority: 3] {TCP} 172.16.60.1:54571 -> 172.16.60.146:80
07/06/2026-21:57:58.699805 [**] [1:1000001:1] Excessive booking API calls detected
[**] [Classification: (null)] [Priority: 3] {TCP} 172.16.60.1:54574 -> 172.16.60.146:80
(이하 동일 패턴 반복)
```

k6가 15초 동안 208,373건의 요청을 전송하는 동안, Suricata가 임계치(초당 20건/IP)를 초과하는 요청을 실시간으로 탐지하여 알림을 생성했다. 탐지 지연은 로그 타임스탬프 기준 밀리초 단위로 확인되었다.

8. 결론

IDS는 탐지 룰의 정교함 이전에 배치 위치가 우선한다는 것을 실습을 통해 확인했다. 별도 모니터링 서버에 배치했을 때는 트래픽 자체를 관찰하지 못해 탐지가 불가능했으며, 실제 트래픽 경로(queue-gate)에 재배치한 이후에는 동일한 공격 패턴을 지연 없이 탐지했다.

9. 후속 과제

1. 현재 탐지 후 대응은 로그 기록에 그치며, 임계치 초과 IP에 대한 자동 차단(ufw 연동)은 구현하지 않았다.
2. ELK(Elasticsearch/Logstash/Kibana) 연동을 통한 로그 시각화 및 장기 보관은 VM 리소스 제약으로 보류했다.
3. fast.log는 로그 로테이션 정책이 설정되어 있지 않아, 장시간 운영 시 디스크 사용량 모니터링이 필요하다.

